

ENTERPRISE SECURITY ASSESSMENT LAB

SCOUTSUITE AWS SECURITY AUDIT

Professional methodology report for automated AWS configuration audit and finding review

Module	Cloud Security Assessment
Document Type	Individual Methodology Report
Phase	Phase 5
Evidence Source	scoutsuite-html-report-overview.png, scoutsuite-specific-high-severity-finding.png
Publication Type	GitHub Portfolio - Redacted Lab Version
Prepared For	04-cloud-security/README.md documentation set
File Name	05-scoutsuite-aws-security-audit-methodology-report.pdf

1. Executive Purpose

ScoutSuite provides a structured cloud configuration audit across AWS services. This methodology section documents how automated findings were generated, reviewed, and interpreted without overclaiming unsupported risks.

2. Scope and Evidence Mapping

Testing objective	Run ScoutSuite against the AWS lab profile and review both the overall dashboard and a specific high-severity finding.
Cloud platform	Amazon Web Services (AWS)
Lab context	CloudGoat / authorized vulnerable cloud lab environment
Primary tools	ScoutSuite, AWS profile, HTML audit report
Evidence file(s)	scoutsuite-html-report-overview.png, scoutsuite-specific-high-severity-finding.png
Result type	AWS audit dashboard and specific security finding reviewed

3. Embedded Evidence Screenshot(s)

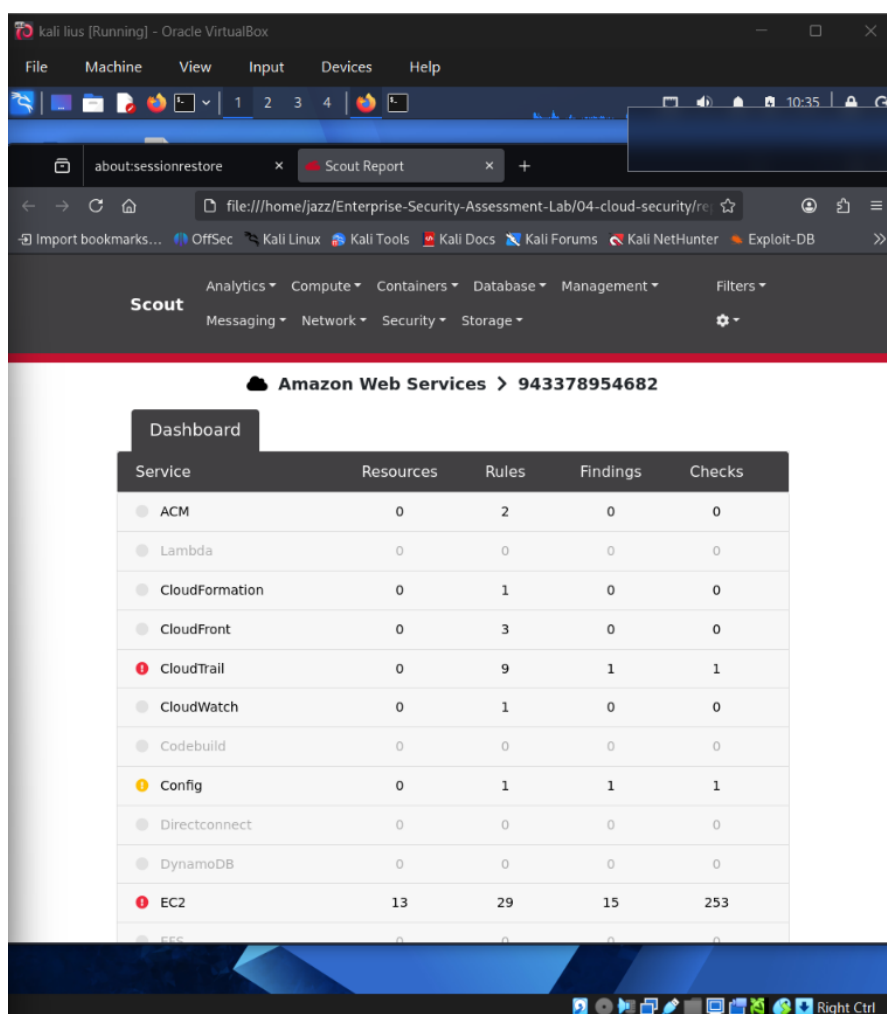


Figure 1 - ScoutSuite AWS audit overview dashboard with account identifiers redacted.

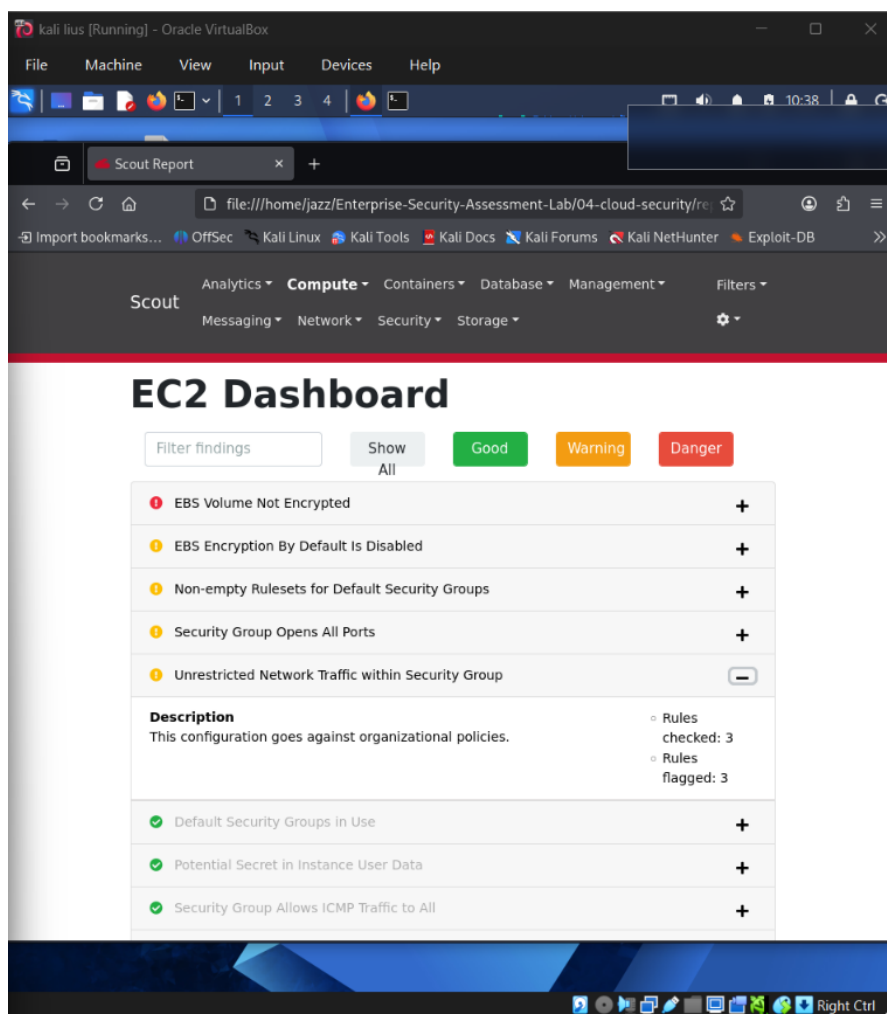


Figure 2 - ScoutSuite specific finding review used for evidence-based reporting.

4. Methodology and Execution Workflow

The tester runs ScoutSuite with the dedicated AWS profile and region, saves the output to a report directory, opens the HTML report, and captures both the summary view and a specific finding. Findings should be validated and prioritized rather than blindly copied.

Command / workflow used

```
scout aws --profile $PROFILE --regions $REGION --no-browser --report-dir ./scoutsuite-report
find ./scoutsuite-report -name "*.html" | head -1
```

Execution notes

- Run ScoutSuite only against the lab account/profile.
- Use the HTML dashboard to understand service-level risk distribution.
- Open a specific finding to capture evidence and remediation context.
- Do not claim services or findings that are not shown in evidence.

5. Sanitized Tool Output Style

The following output example is sanitized. It documents the expected evidence style without exposing AWS account IDs, ARN values, AccessKeyId values, SecretAccessKey values, session tokens, private bucket names, or billing details.

```
ScoutSuite completed AWS audit.  
Report directory: ./scoutsuite-report  
Overview: <REDACTED_ACCOUNT_ID> summary dashboard  
Finding reviewed: <REDACTED_SERVICE_FINDING>
```

Sensitive account identifiers removed for publication.

6. Professional Interpretation

The screenshots prove that an automated cloud security audit was performed and that at least one specific finding was reviewed. This strengthens the cloud section because it shows both tool execution and analyst interpretation.

7. Risk Analysis

Risk Area	Explanation
Configuration drift	Cloud accounts can accumulate weak IAM, S3, EC2, logging, and monitoring configurations over time.
False-positive risk	Automated findings require human validation before being treated as confirmed vulnerabilities.
Prioritization value	ScoutSuite helps triage high-impact issues before lower-impact hardening tasks.

8. Defensive Recommendations

- Run cloud configuration audits regularly.
- Prioritize high-risk IAM, public exposure, and logging/monitoring findings.
- Enable AWS Config, Security Hub, CloudTrail, and GuardDuty where suitable.
- Document accepted risk and remediation status for every material finding.
- Re-run audits after remediation to verify closure.

9. GitHub Redaction and Publication Guidance

Before publishing this document or the underlying screenshot evidence, verify that the following values are removed, blurred, or replaced with placeholders. This is especially important because cloud evidence can contain values that are valid beyond the lab session if not rotated or destroyed.

Sensitive value	Required handling
AWS Account ID	Blur or replace with <REDACTED_ACCOUNT_ID>.
ARN values	Redact account number and private role/user names where needed.
AccessKeyId / SecretAccessKey	Must never be visible. Rotate immediately if exposed.
SessionToken	Must be fully redacted because temporary credentials can still be abused during validity period.
Bucket names / resource names	Redact if they identify private infrastructure or are still active.
ScoutSuite report directory	Do not upload raw unredacted reports if they contain account IDs or resource names.

10. Evidence Quality Checklist

- The screenshot is readable and aligned within the page margins.
- The evidence filename matches the GitHub link exactly.
- The command/output supports the stated result type.
- No AWS credentials, session tokens, account numbers, or private resource identifiers are visible.
- The report explains both the offensive testing value and the defensive remediation value.